

DPDP COMPLIANCE AUDIT

odoo-hackathon-rewear

Digital Personal Data Protection Act 2023



Grade D — At Risk

Indicative penalty exposure: up to Rs 375 crore

DPDP Act 2023 Section 33 (max) — not legal advice

Scanned: 22 March 2026

Files indexed: 124

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

This codebase has 2 critical compliance gap(s) that require immediate attention under the Digital Personal Data Protection Act 2023. An additional 4 significant gap(s) were identified that should be addressed within 30 days. The estimated total remediation effort is 2.4–9.6 engineering days.

Total findings: 15
HIGH: 2
MEDIUM: 4
INFO: 3
PASS: 4

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	0/22 (0%)	FAIL
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	4.0/8 (50%)	WARN
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	8/8 (100%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	4/4 (100%)	PASS

Indicative Penalty Exposure

Up to 375 crore

Maximum indicative penalties under DPDP Act 2023 Section 33 for violations identified in this scan.
Section 33(3): up to 375 crore

Indicative maximum penalties under DPDP Act 2023 Schedule / Section 33. Actual penalties are at regulatory discretion and depend on breach severity, intent, duration, and cooperation. Not legal advice.

Estimated Total Remediation Effort: 2.4–9.6 engineering days

Rule	Section	Severity	File
CONSENT_MISSING_REPO_LEVEL	Section 6 — Consent	HIGH	REPO-WIDE
PASSWORD_NOT_HASHED	Section 8(1) — Security	HIGH	backend/models/index.js
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A

RETENTION_PARTIAL	Section 8(3) — Retention	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
RETENTION_MISSING	Section 8(3) — Retention	MEDIUM	MULTIPLE
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
CONSENT_MISSING	Section 6 — Consent	LOW	backend/routes/index.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	backend/routes/itemRoutes.js
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	backend/routes/authRoutes.js
GRIEVANCE_OFFICER_PRESENT	Section 13 — Grievance Redressal	PASS	frontend/client/src/components/layout/Footer.tsx

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (5–19 hours)

Fix immediately — these represent the highest legal exposure.

- Consent Missing Repo Level — REPO-WIDE (4–16 hrs)
- Password Not Hashed — models/index.js (1–3 hrs)

Week 2 — High Priority (10–42 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Retention Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)
- Retention Missing — MULTIPLE (4–18 hrs)

Week 4 — Advisory (4–16 hours)

Address before next compliance review.

- Data Portability Missing (2–8 hrs)
- Consent Missing — routes/index.js (2–8 hrs)

Total estimated remediation effort: 19–77 hours (2.4–9.6 engineering days)

Details

Finding 1 of 15

[Section 6 — Consent]

1. [HIGH] **CONSENT_MISSING_REPO_LEVEL** — CODEBASE-WIDE

Estimated fix time: 4–16 hours

No consent mechanism detected anywhere in the repository.

Finding 2 of 15

[Section 8(1) — Security]

2. [HIGH] **PASSWORD_NOT_HASHED** — backend / models / index.js

Estimated fix time: 1–3 hours

■ **Penalty exposure:** up to ■250 crore (DPDP Section 33(3))

Model file has password field but no hash/bcrypt/argon/pbkdf2/scrypt/encrypt reference.

Finding 3 of 15

[Section 8(4) — Audit Trail]

3. [MEDIUM] **AUDIT_TRAIL_PARTIAL** — N / A

Estimated fix time: 2–8 hours

■ **Penalty exposure:** up to ■25 crore (DPDP Section 33(3))

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Finding 4 of 15

[Section 8(3) — Retention]

4. [MEDIUM] **RETENTION_PARTIAL** — N / A

Estimated fix time: 2–8 hours

Retention signals found in 4 model(s) but 5 PII model(s) have no retention policy. Uncovered: Item.js, Swap.js, SwapOffer.js.

Finding 5 of 15

[Section 8 — Data Principal Rights]

5. [MEDIUM] **INCOMPLETE_DELETION_COVERAGE** — N / A

Estimated fix time: 2–8 hours

■ **Penalty exposure:** up to ■50 crore (DPDP Section 33(3))

Deletion mechanism detected but may not cover all PII storage. Uncovered files: backend/config/database.js, backend/models/Badge.js, backend/models/EcolImpact.js, backend/models/Item.js, backend/models/Redemption.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Fix:

1. Audit deletion endpoint to ensure it cascades to: backend/config/database.js, backend/models/Badge.js, backend/models/EcolImpact.js, backend/models/Item.js, backend/models/Redemption.js.
2. Use database CASCADE DELETE or explicit multi-table deletion.
3. Add a deletion checklist in code comments listing every table that stores user PII.

Finding 6 of 15

[Section 8(3) — Retention]

6. [MEDIUM] RETENTION_MISSING — MULTIPLE**Estimated fix time:** 4–18 hours**■ Penalty exposure:** up to **■50 crore** (DPDP Section 33(3))**Affected files (5):**

- backend/models/Item.js
- backend/models/Swap.js
- backend/models/SwapOffer.js
- backend/models/User.js
- backend/models/index.js

Model/schema file contains PII fields but no retention or expiry signals detected. Detected in 5 files: Item.js, Swap.js, SwapOffer.js, User.js and 1 more

Finding 7 of 15

[Section 11 — Data Portability]

7. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Finding 8 of 15

[Section 6 — Consent]

8. [LOW] CONSENT_MISSING — backend / routes / index.js:38**Evidence snippet:** 'POST /forgot-password - Forgot password',**Estimated fix time:** 2–8 hours

Authentication form collects email for login/signup. Email use for authentication may qualify as Section 7 legitimate use (contractual necessity). Verify: does the app process this email for purposes beyond authentication? If yes, explicit consent is required.

Finding 9 of 15

[Section 5 — Notice]

9. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 10 of 15

[Section 5 — Purpose Limitation]

10. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 11 of 15

[Section 16 — Cross-Border Transfer]

11. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 12 of 15

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — backend / routes / itemRoutes.js

Data deletion mechanism detected. Found 5 deletion endpoint(s) and 25 deletion signal(s).

Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 15

[Section 8(6) — Breach]

13. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 14 of 15

[Section 11 — Right to Access]

14. [PASS] DATA_ACCESS_PRESENT — backend / routes / authRoutes.js

Data access endpoint detected for authenticated users.

Finding 15 of 15

[Section 13 — Grievance Redressal]

15. [PASS] GRIEVANCE_OFFICER_PRESENT — frontend / client / src / components / layout / Footer.tsx

Grievance Officer or Data Protection Officer contact information detected in codebase.